

DD_EM-CFG-03 - RBAC Catalog

Version: v1.0

Status: Draft for review

Bundle: 10_other

Depends on:

- DD_CROSS-00-System_Traceability_and_Implementation_Map-v1.0
- DD_API-00-API_Catalog_and_Gateway_Standards-v1.0
- FOUNDATION_AUTH
- FOUNDATION_KAFKA
- DD_EM-01-Franchise_Management-v1.0
- DD_EM-02-Contractor_and_Staff_Registry-v1.0
- DD_ILM-CFG-02-Tech_Region_Registry-v1.0

Future dependencies:

- DD_EM-CFG-04-Approval_Workflow_Catalog
- FE-APP-05-Reporting_Portal
- FE-CH-USSD-01-USSD_Channel

1. Purpose

This DD defines the business RBAC catalog for SOPHIX BSS.

FOUNDATION_AUTH owns authentication, Keycloak, JWT validation, and service-token validation. EM-CFG-03 owns the business authorization model layered on top of authentication:

- business role catalog;
- permission catalog;
- role-to-permission matrix;
- user role assignment;
- user scope assignment;
- frontend navigation/action visibility matrix;
- API authorization lookup contract.

Without this DD, every module and frontend would invent local role names. That creates inconsistent security and makes implementation hard to test.

2. What This Module Is For

Use EM-CFG-03 when the system needs to answer:

Question	EM-CFG-03 answer
Which roles exist in this operator deployment?	Read role catalog.
What can a role do?	Read role-permission matrix.
Which user has which business roles?	Read user role assignments, or mirror Keycloak groups into assignments.
Which franchise/region/team can this user operate on?	Read user scope assignments.
Should Backoffice show this menu/action?	Read frontend role/action matrix.
Should an API allow this command?	Module checks JWT plus RBAC permission/scope.
Which roles can approve future workflows?	Approval catalog will reference role/permission codes from this DD.

Kenya/WIK is first, but the model must support future operators with different roles, languages, franchise structures, and organization names.

3. Scope

Included:

Capability	Purpose
Role catalog	Canonical business roles like customer care agent, billing lead, dispatcher, franchise manager.
Permission catalog	Canonical permissions like <code>ticket.create</code> , <code>invoice.read</code> , <code>franchise.manage</code> .
Role-permission matrix	Which permissions each role grants.
User role assignment	Assign business roles to users, optionally synchronized from Keycloak groups.
Scope assignment	Restrict a user's permissions by operator, franchise, tech region, contractor, team, or channel.
Effective access API	Compute a user's permissions and scopes for a frontend or module.
Frontend menu/action matrix	UI visibility rules for Backoffice and mobile apps.
RBAC events	Notify modules/frontends when role or scope assignments change.

Out of scope:

Out of scope	Owner
Login, SSO, passwords, MFA	FOUNDATION_AUTH / Keycloak
JWT signing and validation	FOUNDATION_AUTH
Service-to-service token validation	FOUNDATION_AUTH
External gateway callback authentication	Gateway-specific DDs
Approval workflow steps and thresholds	Future EM-CFG-04
Data masking rules beyond permission flags	Module DDs, using RBAC permissions where needed
HR/payroll/staff lifecycle	EM-02 or external HR

4. Ownership Boundary With FOUNDATION_AUTH

Concern	Owner	Rule
User login and sessions	FOUNDATION_AUTH	Keycloak authenticates users and issues tokens.
JWT roles claim	FOUNDATION_AUTH	Token contains coarse roles/groups.
Business role catalog	EM-CFG-03	Defines canonical role codes and descriptions.
Permission catalog	EM-CFG-03	Defines permission codes modules enforce.
User scopes	EM-CFG-03	Defines which operator/franchise/region/team a user can act on.
API enforcement	Owning module, using EM-CFG-03	Module remains the final authority for its endpoint.
Frontend visibility	FE apps, using EM-CFG-03 matrix	Hidden buttons are UX only, not security.

Implementation rule: a module must never trust the frontend. Every protected endpoint validates the JWT, then checks required permission and scope server-side.

5. Core Concepts

Concept	Meaning
Role	Business job function, for example <code>CUSTOMER_CARE_AGENT</code> .
Permission	Atomic action right, for example <code>ticket.create</code> or <code>invoice.adjust.approve</code> .

Concept	Meaning
Scope	Boundary where a permission applies: operator, franchise, tech region, contractor, team, channel, or global.
Role assignment	Granting a role to a user.
Scope assignment	Granting a user access to a specific scope value, for example franchise WIK-NRB-002.
Effective access	Computed result of roles + permissions + scopes + status.
Role family	User-facing grouping for frontend navigation, for example Billing.

6. Default Role Families

These are role families used by frontend and implementation teams. Exact role codes can be adjusted per operator, but keep the family/purpose stable.

Role family	Typical role codes	Main modules
Super admin	SUPER_ADMIN, PLATFORM_ADMIN	All modules, foundation admin.
Read-only auditor	READ_ONLY_AUDITOR	All read APIs within assigned scope.
Customer care	CUSTOMER_CARE_AGENT, CUSTOMER_CARE_SUPERVISOR	ILM, TCK, NOT/ICN, limited SUB/BIL reads.
KYC	KYC_REVIEWER_L1, KYC_REVIEWER_L2	ILM, FUL-02 KYC tasks.
Subscription operations	SUBSCRIPTION_OPERATOR, SUBSCRIPTION_SUPERVISOR	SUB-LM, SUB-WF.
Billing	BILLING_OPERATOR, BILLING_LEAD, DUNNING_ADMIN, WALLET_ADMIN	BIL modules.
Fulfillment	FULFILLMENT_OPERATOR, FULFILLMENT_SUPERVISOR	FUL, SUB-WF, WO read.
Dispatch/work order	DISPATCHER, WO_SUPERVISOR	WO, EM-02, OSR read.
Equipment/stock	OSR_OPERATOR, OSR_SUPERVISOR, INVENTORY_AUDITOR	OSR modules.
Catalog admin	PRODUCT_MANAGER, CATALOG_ADMIN, HOME_PASS_ADMIN	PLM, SIP, RLM, BIL-CFG.
Sales/franchise	SALES_AGENT, SALES_SUPERVISOR, FRANCHISE_MANAGER	SALES, EM-01, FUL-02 order capture.
Workforce admin	WORKFORCE_ADMIN, CONTRACTOR_ADMIN	EM-02.
Reporting	REPORT_VIEWER, REPORT_EXPORTER, REPORT_ADMIN	REP, FE-APP-05.
Customer self-care	CUSTOMER_SELF CARE	Self-care APIs only.

7. Data Ownership

EM-CFG-03 owns:

Entity	Purpose
rbac_role	Business role catalog.
rbac_permission	Atomic permission catalog.
rbac_role_permission	Role-to-permission matrix.
rbac_user_role_assignment	User-to-role assignment.
rbac_user_scope_assignment	User-to-scope assignment.
rbac_frontend_action	Frontend menu/action catalog.
rbac_role_frontend_action	Role-to-frontend action visibility matrix.
rbac_change_audit	Immutable audit of RBAC changes.

EM-CFG-03 references:

Reference	Owner
auth_user_id	FOUNDATION_AUTH / Keycloak
franchise_id	EM-01
contractor_id	EM-02
team_id	EM-02
tech_region_code	ILM-CFG-02 / RLM-CFG-01

8. Core Tables

8.1 rbac_role

What it is for: stores the canonical business roles available in an operator deployment.

When to use it: seed roles, show role admin screens, validate role assignments, map frontend role families.

Column	Type	Purpose	Sample
role_id	TEXT PK	Stable role row id.	role_01J_CC_AGENT
operator_code	TEXT	Operator scope. Use GLOBAL for platform-wide seed roles.	WIK
role_code	TEXT	Stable business code.	CUSTOMER_CARE_AGENT
display_name	TEXT	Human-readable name.	Customer Care Agent
role_family	TEXT	UI/business family.	CUSTOMER_CARE
description	TEXT	What this role is for.	Can search customers and create support tickets.
status	TEXT	DRAFT, ACTIVE, RETIRED.	ACTIVE
keycloak_role_name	TEXT NULL	Matching Keycloak role/group if mirrored.	CUSTOMER_CARE_AGENT
created_at	TIMESTAMP	Creation timestamp.	2026-05-29T11:00:00Z
updated_at	TIMESTAMP	Last update timestamp.	2026-05-29T11:00:00Z

Constraints:

- Unique (operator_code, role_code).
- Active role must have at least one permission unless it is intentionally used as a grouping role.

8.2 rbac_permission

What it is for: stores atomic permissions that APIs and frontends can reference.

When to use it: define endpoint guards and high-risk action checks.

Column	Type	Purpose	Sample
permission_id	TEXT PK	Permission row id.	perm_ticket_create
permission_code	TEXT UNIQUE	Stable permission code.	ticket.create
module_code	TEXT	Owning module.	TCK-01
action_group	TEXT	Broad grouping.	ticket
risk_level	TEXT	LOW, MEDIUM, HIGH, CRITICAL.	LOW
description	TEXT	What this permission allows.	Create customer ticket.
scope_required	BOOLEAN	Whether scope must be checked.	true
status	TEXT	ACTIVE, RETIRED.	ACTIVE
created_at	TIMESTAMP	Creation timestamp.	2026-05-29T11:05:00Z

8.3 rbac_role_permission

What it is for: links roles to permissions.

When to use it: compute effective access for a user with a role.

Column	Type	Purpose	Sample
role_permission_id	TEXT PK	Row id.	rp_01J_CC_TCK_CREATE
role_id	TEXT FK	Role.	role_01J_CC_AGENT
permission_id	TEXT FK	Permission.	perm_ticket_create
effect	TEXT	ALLOW or DENY. Deny is for explicit exceptions.	ALLOW
condition_json	JSONB	Optional simple condition metadata.	{"ticketSource":["CALL_CENTER","BACKOFFICE"]}
active	BOOLEAN	Whether grant applies.	true
created_at	TIMESTAMP	Creation timestamp.	2026-05-29T11:10:00Z

Rule: keep conditions simple. Complex approval or threshold logic belongs in EM-CFG-04 or the owning module.

8.4 rbac_user_role_assignment

What it is for: stores which business roles are assigned to a user.

When to use it: user admin, access computation, and auditing. It can be synchronized from Keycloak groups or managed in Backoffice if allowed.

Column	Type	Purpose	Sample
assignment_id	TEXT PK	Assignment id.	ura_01J_ALICE_CC
operator_code	TEXT	Operator scope.	WIK
auth_user_id	TEXT	Keycloak subject/user id.	kc_user_alice
role_id	TEXT FK	Assigned role.	role_01J_CC_AGENT
source	TEXT	KEYCLOAK_GROUP, BACKOFFICE_ADMIN, IMPORT.	KEYCLOAK_GROUP
effective_from	TIMESTAMP	Start time.	2026-05-29T11:00:00Z
effective_to	TIMESTAMP NULL	End time.	null
active	BOOLEAN	Current assignment flag.	true
created_by_user_id	TEXT	Actor who created assignment.	kc_user_admin
created_at	TIMESTAMP	Creation timestamp.	2026-05-29T11:15:00Z

8.5 rbac_user_scope_assignment

What it is for: stores where a user's permissions apply.

When to use it: restrict a user to an operator, franchise, tech region, contractor, team, or channel.

Column	Type	Purpose	Sample
scope_assignment_id	TEXT PK	Scope assignment id.	usa_01J_ALICE_FR002
operator_code	TEXT	Operator scope.	WIK
auth_user_id	TEXT	Keycloak subject/user id.	kc_user_alice
scope_type	TEXT	OPERATOR, FRANCHISE, TECH_REGION, CONTRACTOR, TEAM, CHANNEL, GLOBAL.	FRANCHISE
scope_value	TEXT	Scope value/id.	fr_01J_NRB_002
scope_label	TEXT NULL	Human display label.	Nairobi 002
effective_from	TIMESTAMP	Start time.	2026-05-29T11:00:00Z
effective_to	TIMESTAMP NULL	End time.	null
active	BOOLEAN	Current assignment flag.	true
created_by_user_id	TEXT	Actor.	kc_user_admin
created_at	TIMESTAMP	Creation timestamp.	2026-05-29T11:20:00Z

Scope rules:

- A GLOBAL scope should be rare and limited to platform administrators.
- A user can have multiple scope assignments.

- If a permission has `scope_required = true`, module APIs must verify the target entity falls within one of the user's active scopes.

8.6 rbac_frontend_action

What it is for: stores named frontend menus, screens, buttons, and actions.

When to use it: make Backoffice and mobile navigation consistent with RBAC.

Column	Type	Purpose	Sample
frontend_action_id	TEXT PK	Action id.	fea_bo_ticket_create
app_code	TEXT	Frontend app.	FE-APP-01
action_code	TEXT	Stable action code.	backoffice.tickets.create
action_type	TEXT	MENU, SCREEN, BUTTON, TAB, FIELD.	BUTTON
display_name	TEXT	Admin label.	Create Ticket
required_permission_code	TEXT NULL	Permission needed for action.	ticket.create
feature_flag	TEXT NULL	Optional feature flag.	ticketingEnabled
status	TEXT	ACTIVE, RETIRED.	ACTIVE

8.7 rbac_role_frontend_action

What it is for: optional precomputed mapping from roles to frontend actions.

When to use it: speed up UI navigation/action matrix loading. This mapping must not replace API authorization.

Column	Type	Purpose	Sample
role_action_id	TEXT PK	Row id.	rfa_01J_CC_TICKET_CREATE
role_id	TEXT FK	Role.	role_01J_CC_AGENT
frontend_action_id	TEXT FK	Frontend action.	fea_bo_ticket_create
visible	BOOLEAN	Whether UI can show it.	true
enabled	BOOLEAN	Whether UI can enable it by default.	true
active	BOOLEAN	Whether mapping is active.	true

8.8 rbac_change_audit

What it is for: immutable audit trail for RBAC changes.

When to use it: security audit, admin review, incident investigation, and access reconstruction.

Column	Type	Purpose	Sample
audit_id	TEXT PK	Audit row id.	rba_01J_ASSIGN
operator_code	TEXT	Operator scope.	WIK
change_type	TEXT	Type of change.	USER_ROLE_ASSIGNED
target_type	TEXT	ROLE, PERMISSION, USER_ROLE, USER_SCOPE, FRONTEND_ACTION.	USER_ROLE
target_id	TEXT	Changed entity id.	ura_01J_ALICE_CC
actor_user_id	TEXT	Admin/system actor.	kc_user_admin
before_json	JSONB NULL	Previous state.	null
after_json	JSONB	New state.	{"roleCode": "CUSTOMER_CARE_AGENT"}
reason_code	TEXT NULL	Reason.	NEW_HIRE
created_at	TIMESTAMP	Audit timestamp.	2026-05-29T11:25:00Z

9. Permission Seed Matrix

Initial permissions should include at least:

Permission	Module	Risk	Purpose
customer.read	ILM	LOW	View customer profile within scope.
customer.update	ILM	MEDIUM	Update allowed customer fields.
customer.kyc.review_l1	ILM/FUL	HIGH	First-level KYC review.
customer.kyc.review_l2	ILM/FUL	HIGH	Final KYC review.
ticket.read	TCK	LOW	View tickets within scope.
ticket.create	TCK	LOW	Create tickets.
ticket.assign	TCK	MEDIUM	Assign/reassign tickets.
ticket.resolve	TCK	MEDIUM	Resolve tickets.
subscription.read	SUB-LM	LOW	View subscription.
subscription.command	SUB-WF	HIGH	Start lifecycle/MACD operations.
billing.invoice.read	BIL	LOW	View invoices.
billing.payment.read	BIL	LOW	View payments.
billing.adjustment.create	BIL	HIGH	Create adjustment/dispute.
billing.adjustment.approve	BIL	CRITICAL	Approve adjustment/write-off.
wallet.read	BIL-05	LOW	View wallet.
wallet.adjust	BIL-05	CRITICAL	Adjust wallet manually.
fulfillment.read	FUL	LOW	View orders/executions.
fulfillment.retry	FUL	HIGH	Retry failed fulfillment step.
workorder.read	WO	LOW	View WOs.
workorder.assign	WO	HIGH	Assign/reassign WO.
workorder.finalize_review	WO	HIGH	Review/finalize evidence.
osr.stock.read	OSR	LOW	View stock.
osr.stock.move	OSR	HIGH	Move stock.
catalog.manage	PLM/SIP/RLM	HIGH	Manage catalogs.
franchise.manage	EM-01	HIGH	Manage franchise master and assignments.
rbac.manage	EM-CFG-03	CRITICAL	Manage roles/permissions/scopes.
report.view	REP	LOW	View reports.
report.export	REP	HIGH	Export reports.

Each module DD should reference permission codes from this catalog when documenting endpoints.

10. APIs

All APIs require Authorization: Bearer <jwt>.

Write APIs require Idempotency-Key.

10.1 Catalog APIs

API	Purpose	Consumers
GET /api/rbac/roles?operatorCode=WIK&status=ACTIVE	List roles.	Backoffice admin, modules.
POST /api/rbac/roles	Create role.	RBAC admin.
PATCH /api/rbac/roles/{role_id}	Update role metadata/status.	RBAC admin.
GET /api/rbac/permissions?moduleCode=TK-01	List permissions.	Backoffice admin, module config.
POST /api/rbac/permissions	Create permission.	Platform/RBAC admin.
POST /api/rbac/roles/{role_id}/permissions	Add permission to role.	RBAC admin.
DELETE /api/rbac/role-permissions/{role_id}/{permission_id}	Remove role permission.	RBAC admin.

10.2 Assignment APIs

API	Purpose	Consumers
GET /api/rbac/users/{auth_user_id}/roles	Read user roles.	Backoffice, modules.
POST /api/rbac/users/{auth_user_id}/roles	Assign role.	RBAC admin.
DELETE /api/rbac/user-role-assignments/{assignment_id}	End role assignment.	RBAC admin.
GET /api/rbac/users/{auth_user_id}/scopes	Read user scopes.	Backoffice, modules.
POST /api/rbac/users/{auth_user_id}/scopes	Assign scope.	RBAC admin.
DELETE /api/rbac/user-scope-assignment/{scope_assignment_id}	End scope assignment.	RBAC admin.

10.3 Effective Access APIs

API	Purpose	Consumers
GET /api/rbac/users/{auth_user_id}/effective-access?appCode=FE-APP-01	Role/permission/scope/action matrix for app shell.	FE apps, BFF if used.
POST /api/rbac/check	Check one permission/scope decision.	Modules, gateway/BFF.
POST /api/rbac/check-bulk	Check several decisions for a screen.	Frontend BFF, Backoffice.

Effective access response sample:

```
{
  "authUserId": "kc_user_alice",
  "operatorCode": "WIK",
  "roles": ["CUSTOMER_CARE_AGENT"],
  "permissions": ["customer.read", "ticket.read", "ticket.create"],
  "scopes": [
    {
      "scopeType": "FRANCHISE",
      "scopeValue": "fr_01J_NRB_002",
      "scopeLabel": "Nairobi 002"
    }
  ],
  "frontendActions": [
    {
      "actionCode": "backoffice.customers.search",
      "visible": true,
      "enabled": true
    },
    {
      "actionCode": "backoffice.tickets.create",
      "visible": true,
      "enabled": true
    }
  ]
}
```

RBAC check request:

```
{
  "operatorCode": "WIK",
  "authUserId": "kc_user_alice",
  "permissionCode": "ticket.create",
  "target": {
    "scopeType": "FRANCHISE",
    "scopeValue": "fr_01J_NRB_002"
  }
}
```

RBAC check response:

```
{
  "decision": "ALLOW",
  "reason": "ROLE_PERMISSION_AND_SCOPE_MATCH",
  "matchedRoles": ["CUSTOMER_CARE_AGENT"],
  "matchedScopes": ["fr_01J_NRB_002"]
}
```

11. Business Rules

Rule	Description
RBAC-1	Modules must validate JWT first, then permission, then scope.
RBAC-2	Frontend role/action matrix is UX only; backend authorization remains authoritative.
RBAC-3	Role codes and permission codes are stable API contracts and must not be renamed casually.
RBAC-4	A user without active role assignment has no business permissions, even if authenticated.
RBAC-5	A permission with <code>scope_required = true</code> must match target scope.
RBAC-6	GLOBAL scope is only allowed for approved admin roles.
RBAC-7	Critical permissions like <code>rbac.manage</code> , <code>wallet.adjust</code> , and <code>billing.adjustment.approve</code> must be audited.
RBAC-8	Removing a role assignment takes effect on next access check; tokens may still contain old coarse roles until expiry, so modules should use RBAC effective access for high-risk actions.
RBAC-9	Keycloak groups may seed role assignments, but EM-CFG-03 remains the business catalog used by BSS modules.
RBAC-10	Scope assignment values must resolve to their owning module before activation.

12. Events

Event	Topic	Meaning	Consumers
RbacRoleCreated	<code>sophix.rbac.role-created</code>	Role added.	Backoffice cache, audit, REP.
RbacPermissionCreated	<code>sophix.rbac.permission-created</code>	Permission added.	Backoffice cache, audit.
RbacRolePermissionChanged	<code>sophix.rbac.role-permission-changed</code>	Role permission matrix changed.	Modules, FE cache, audit.
RbacUserRoleAssigned	<code>sophix.rbac.user-role-assigned</code>	User role assigned.	FE cache, modules, audit.
RbacUserRoleRevoked	<code>sophix.rbac.user-role-revoked</code>	User role ended.	FE cache, modules, audit.
RbacUserScopeAssigned	<code>sophix.rbac.user-scope-assigned</code>	User scope assigned.	FE cache, modules, audit.
RbacUserScopeRevoked	<code>sophix.rbac.user-scope-revoked</code>	User scope ended.	FE cache, modules, audit.

Events must be emitted through transactional outbox after DB commit.

13. Frontend Usage

13.1 FE-APP-01 Backoffice

Backoffice uses EM-CFG-03 for:

Area	API
App shell navigation	GET <code>/api/rbac/users/{user_id}/effective-access?appCode=FE-APP-01</code>
Screen actions/buttons	Effective access API or bulk check.
User role administration	Role and assignment APIs.
User franchise/region scope admin	Scope assignment APIs.
Sensitive action confirmation	Backend module still performs final permission check.

13.2 FE-APP-02 Outdoor Sales App

Sales app uses EM-CFG-03 for:

Area	API
Sales/franchise role visibility	Effective access API with appCode=FE - APP - 02.
Franchise scope	Scope assignments, usually FRANCHISE or TEAM.
Supervisor actions	Bulk check for lead reassignment/override actions.

13.3 FE-APP-03 Contractor App

Contractor app uses EM-CFG-03 for:

Area	API
Contractor user scope	CONTRACTOR or TEAM scope.
Job actions	Permissions such as <code>workorder.read</code> , <code>workorder.finalize_review</code> where applicable.

13.4 FE-APP-04 Customer Self-Care

Customer self-care normally uses customer-account scope from customer authentication mapping, not staff RBAC. If the same RBAC service is used, the role must be CUSTOMER_SELFCARE and the scope must be customer/account-bound. Staff roles must never grant access to customer self-care accounts.

14. Integration With Modules

Module	Integration
FOUNDATION_AUTH	Provides JWT/auth user id and coarse roles/groups.
EM-01	Validates franchise scopes.
EM-02	Validates contractor/team scopes.
ILM/RLM	Validates tech region/homepass-derived scopes where needed.
TCK	Checks ticket permissions and customer/franchise scope.
SUB-WF	Checks lifecycle command permissions.
BIL	Checks invoice/payment/wallet permissions and high-risk operations.
WO	Checks dispatch/assignment/finalization permissions.
OSR	Checks stock/equipment permissions.
REP	Checks report view/export permissions and scope masking.
FE apps	Render menus/actions from effective access.

15. Infrastructure And Deployment

For a budget-conscious medium deployment:

Component	Recommendation
Runtime	Run inside EM/business-services pod with EM-01 and EM-02.
Database	PostgreSQL em or rbac schema in shared business DB.
Cache	Redis for effective-access cache with short TTL, for example 2-5 minutes.
Kafka	Outbox events for cache invalidation and audit.
Keycloak	Keep as authentication source; mirror groups/roles through sync job if needed.
Camunda	Not required. Approval workflows use EM-CFG-04 later.
Drools	Not required. Permission checks should be deterministic service logic.
Observability	Track deny rates, RBAC lookup latency, cache hit rate, sync failures, and high-risk permission changes.

AWS recommendation:

Concern	AWS guidance
Compute	Shared EM ECS/EKS service.
DB	Existing RDS PostgreSQL.
Cache	Existing ElastiCache Redis if deployed.
Events	Existing MSK/Kafka.
Secrets	Secrets Manager/SSM for Keycloak admin sync credentials.
Audit	Push RBAC audit events into central log/SIEM if available.

16. Security Notes

- Never allow a frontend-only decision to authorize an API write.
- Never accept actorUserId or role from request body for user actions. Use JWT principal.
- Cache effective access briefly, but invalidate on RBAC change events.
- For high-risk actions, modules should call POST /api/rbac/check or use a freshly loaded effective access snapshot.
- Keep role and scope changes auditable forever.
- Do not expose all role assignments to ordinary users. Only administrators can browse role assignment data.

17. Tests

Minimum tests:

Test	Expected result
User with role and matching scope checks permission	ALLOW.
User with role but missing target scope	DENY.
User with scope but missing permission	DENY.
Inactive role assignment	DENY.
Retired permission	Not granted.
Same idempotency key and same assignment payload	Same response, no duplicate row.
Same idempotency key with different payload	409.
Scope assignment to unknown franchise	422.
Effective access for Backoffice	Returns roles, permissions, scopes, and frontend actions.
Role removal invalidates cache	Next effective access no longer includes role.
Critical permission change	Audit row and outbox event created.

18. Open Decisions For Review

Decision	Recommendation
Should roles be assigned only in Keycloak or also in BSS?	Support both. Keycloak authenticates and can seed groups; EM-CFG-03 is the business RBAC catalog and effective access source.
Should modules call RBAC on every request?	For low-risk reads, modules may cache effective access briefly. For high-risk writes, call/check freshly.
Should permissions be global or operator-specific?	Permission codes are global; role composition and assignments are operator-specific.
Should frontend action matrix be generated from permissions?	Mostly yes, but keep explicit frontend action rows for menu/screen behavior and feature flags.
Should customer self-care use this RBAC module?	Only carefully. Customer account scoping is different from staff RBAC; self-care must never inherit staff permissions.